

Cybersecurity

Introduction to Security Within the Organization

Lesson 22.1



Learning Objectives

By the end of today's lesson, you'll be able to:

- 1 Identify at least three concrete benefits of a healthy security culture.
- 2 Explain the responsibilities of common C-suite officers, including the CISO.
- 3 Explain the responsibilities of a security department.
- 4 Identify appropriate security controls for a given resource and situation.



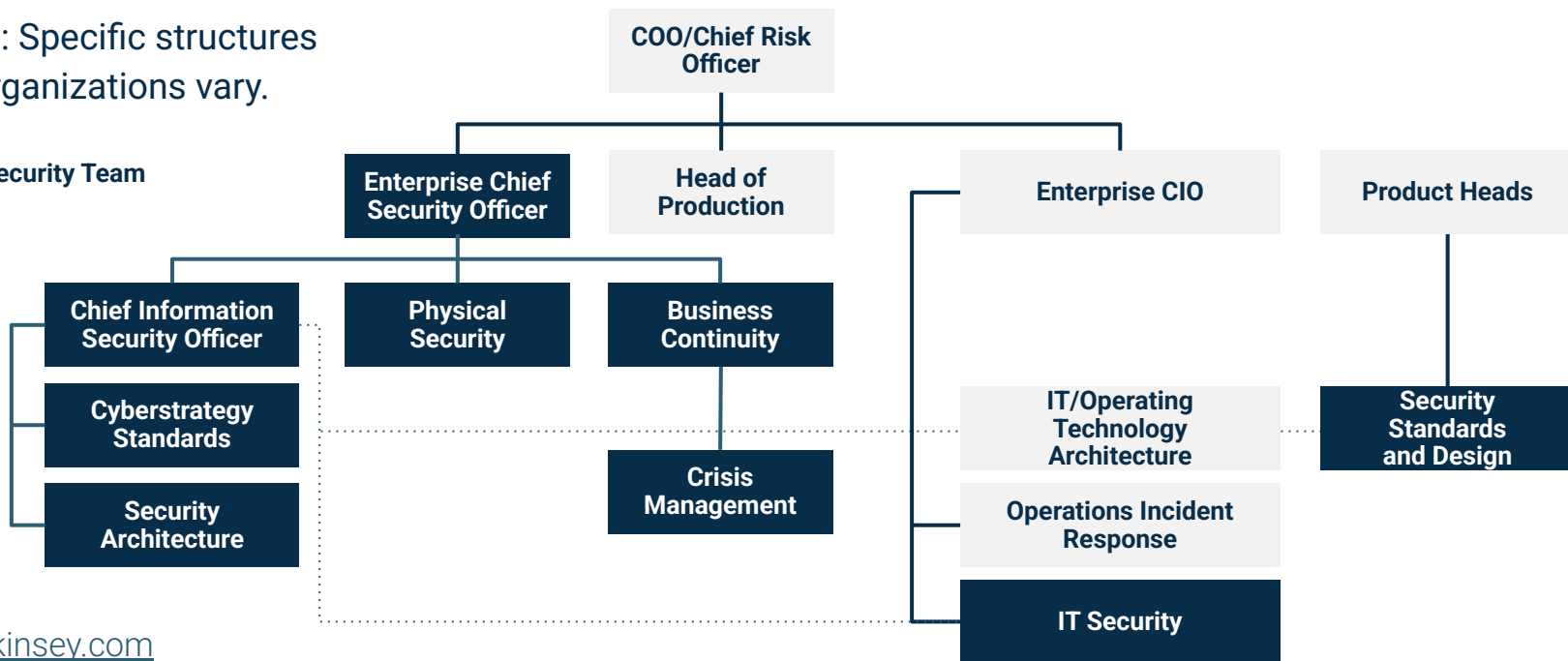
Security Aligning With an **Organization**

Security Aligning With an Organization

Throughout this course, you will be equipped with the tools you need to perform in common technical roles. Today, we will see how these roles interact with one another and operate within the larger organization.

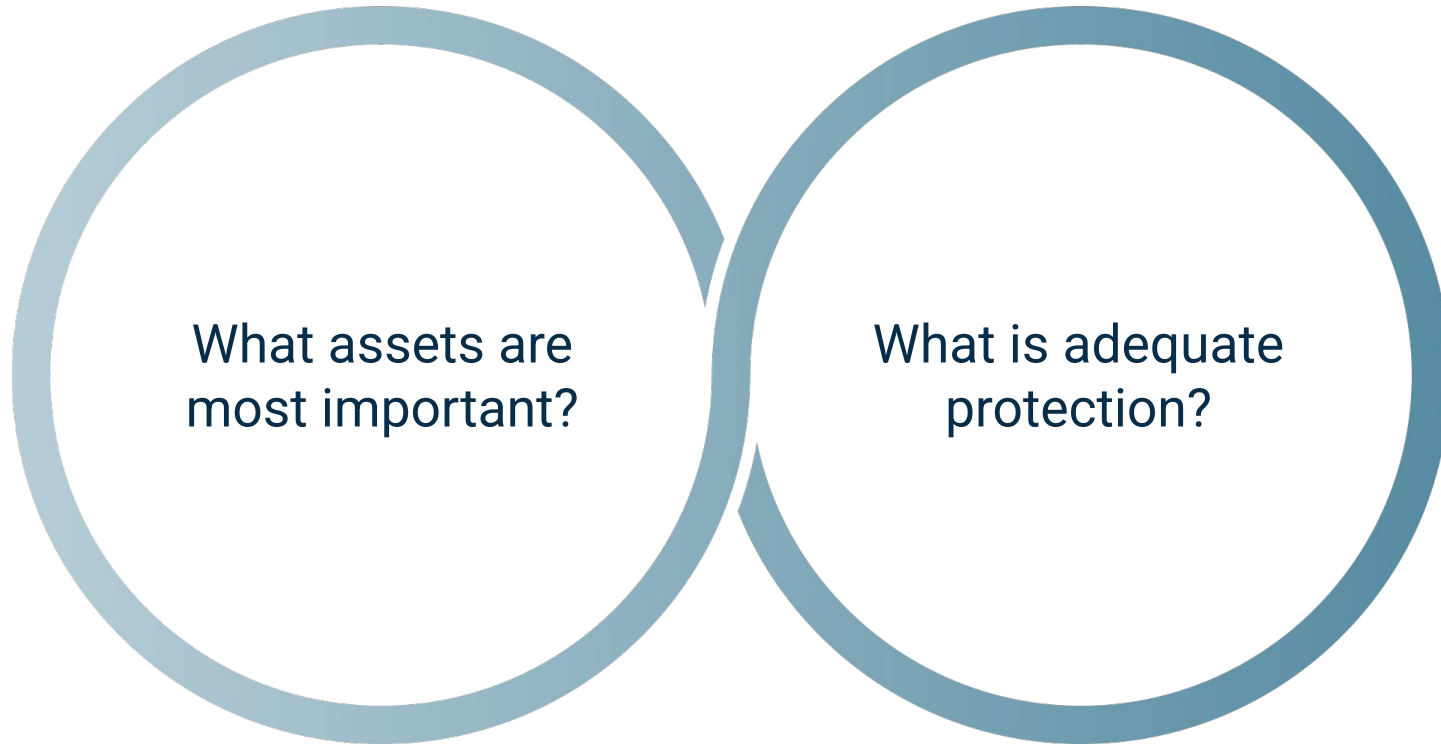
Example: Specific structures within organizations vary.

■ Cybersecurity Team



GRC Framework

GRC is a framework for answering the following questions:



GRC Framework

Governance

Creating management processes for implementing security practices across the organization.

Risk Management

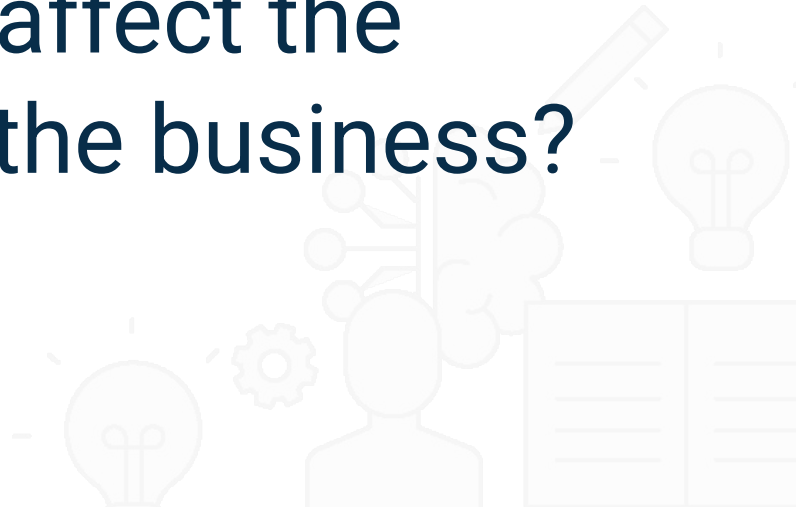
Identifying an organization's most important assets and determining how they might be compromised.

Compliance

Making sure the business follows internal security policies and adheres to relevant security laws.

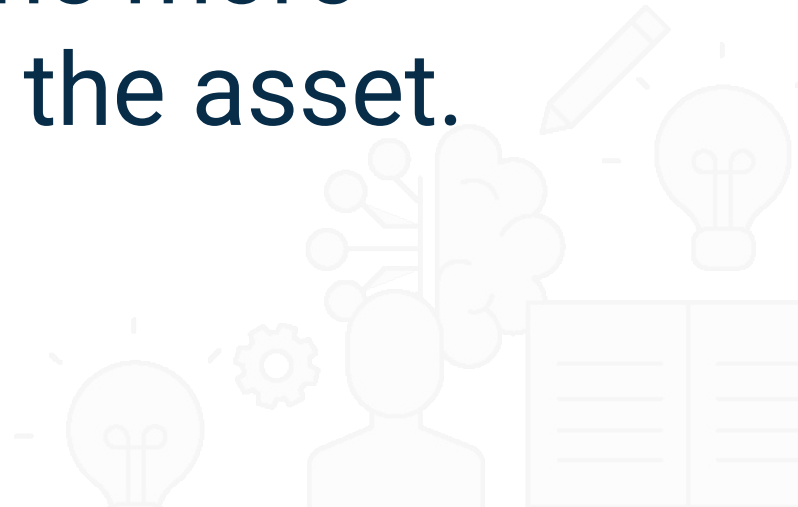


**We define “important”
by asking:** How would a
security compromise of
this asset affect the
profits of the business?





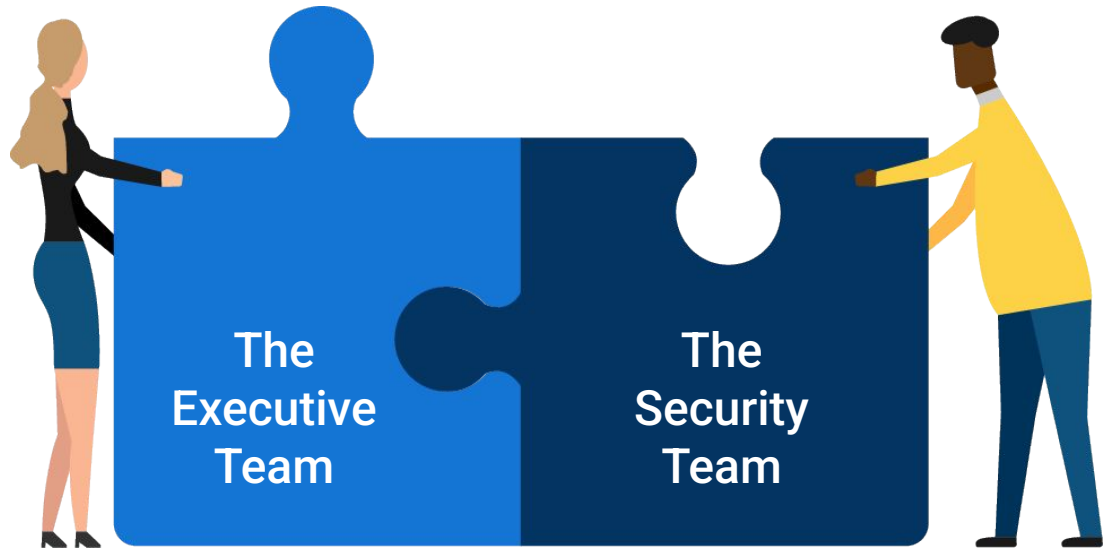
The more significant
the loss, the more
important the asset.



GRC Framework

We will study how GRC frameworks are considered and implemented into a business by first examining the following:

The **executive management team** is ultimately responsible for the adherence and enforcement of laws, regulations, and security practices.



Security Management



Planning and defining security roles.



Developing security policies.



Performing risk analysis.



Developing strategic, tactical, and operational plans.

Security Management

Strategic Plan: Long-term plan that aligns with organization's goals, mission, and objectives.

5 years

Tactical Plan: Mid-term plan that details how to accomplish the goals set in the strategic plan.

1 year

Operational Plan: Short-term, highly detailed plan based on strategic and tactical plan.

Monthly or quarterly

Strategic

Tactical

Operational





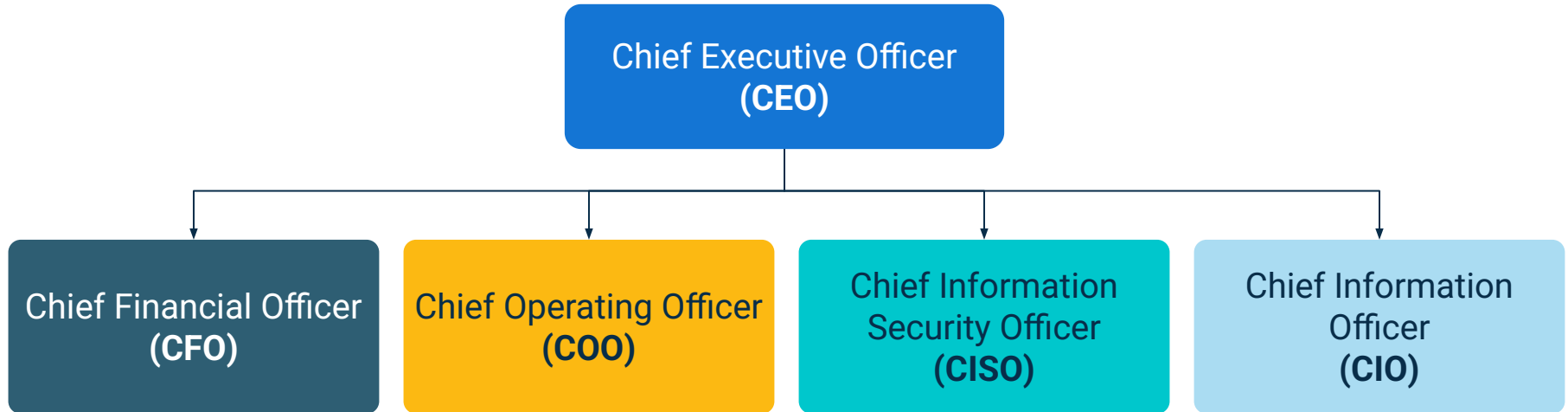
Security Roles and Responsibilities

In the next section, we'll cover the following:

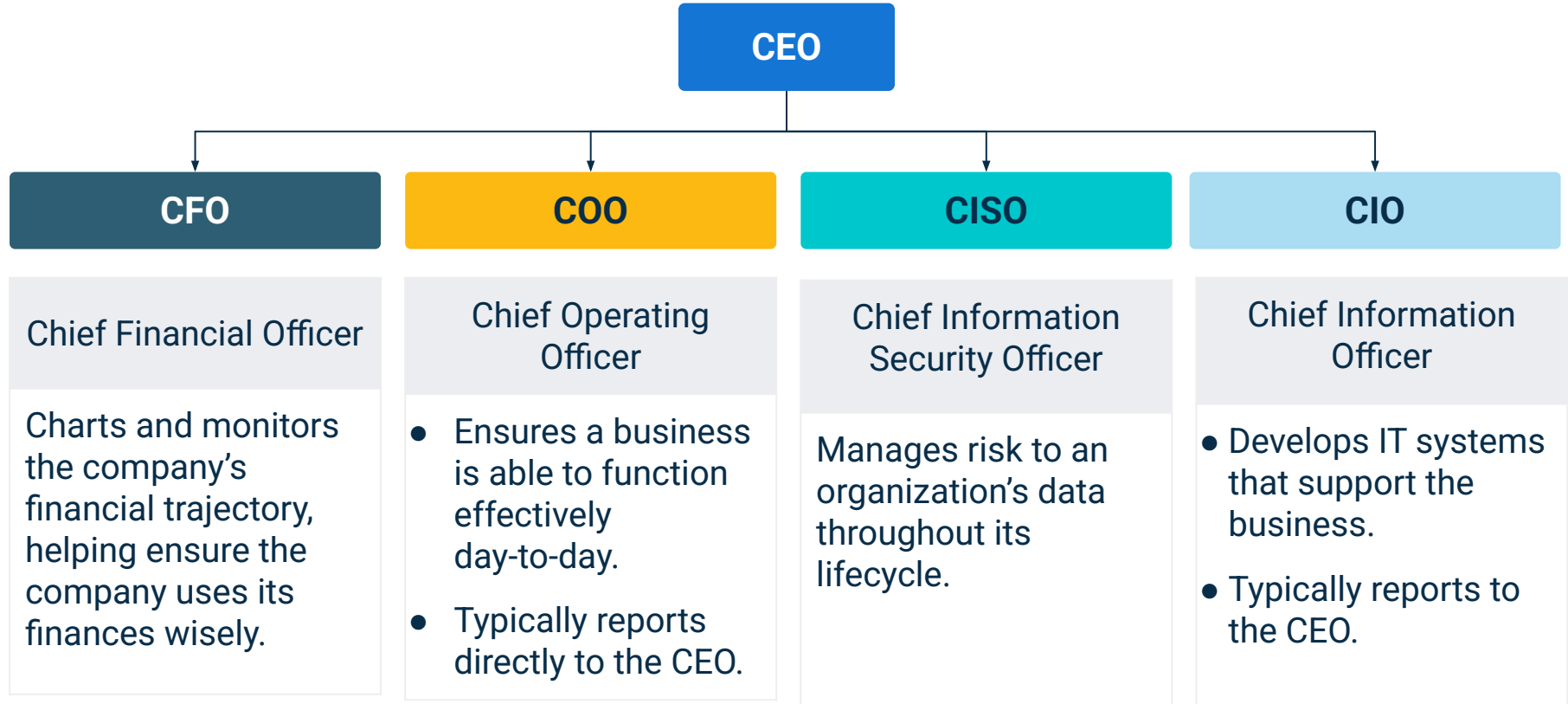
- 1 Executive roles existing in most companies.
- 2 Executive roles relevant to security departments.
- 3 The responsibilities of security departments.
- 4 The structure of the security organization.

Executive Roles: The Core Leadership Team

The **CEO** is responsible for plotting the overall direction of the company. They report to the **board of directors**. This group is elected by shareholders and holds the CEO accountable for meeting their demands.



Executive Roles: The Core Leadership Team



The Responsibilities of the Security Department

The CISO is responsible for protecting the company's data, often supervising the following teams, among others:

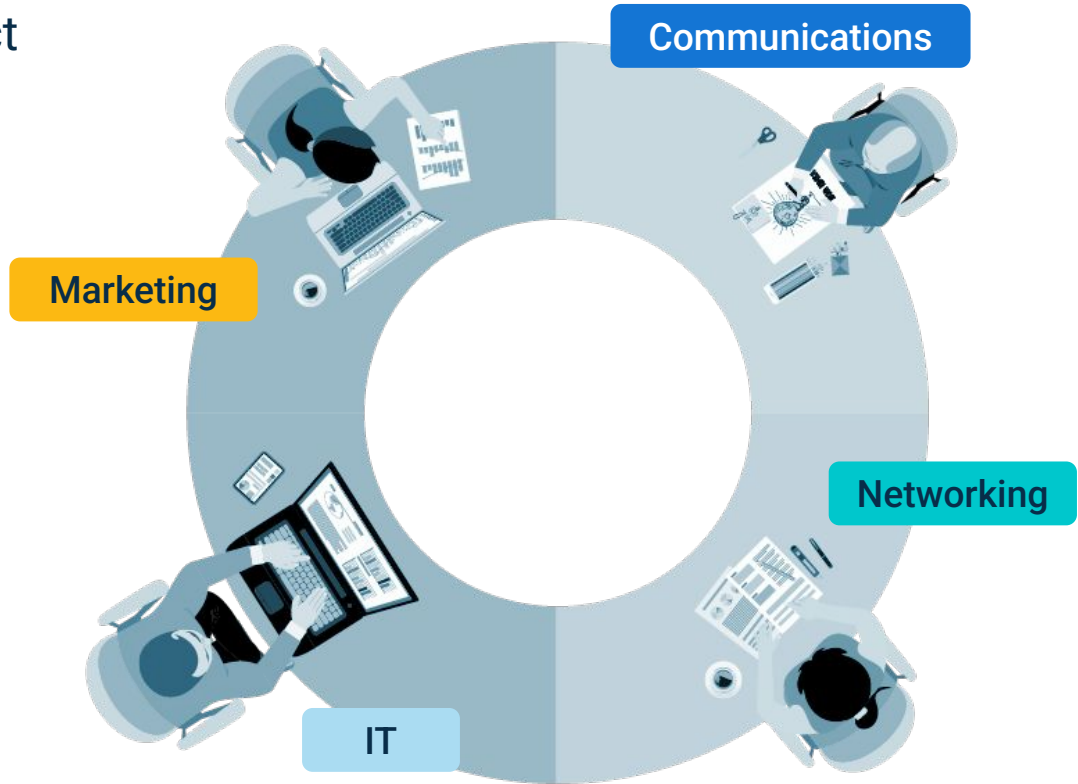
Department	Position	Supervises
Network Security	Director of networking or director of network security is in charge of networks.	A director of networking often has system administrators, network administrators, and physical network technicians on staff. They may also manage a help desk.
Incident Response	IR manager or SOC manager manages an incident response unit.	A SOC manager employs SOC analysts, also known as security analysts or incident handlers.
Application Security	Security architect is in charge of application security.	A security architect typically manages security engineers and software engineers.

Security and the Larger Organization

Security operations will interact with other non-security teams within the organization.

For example:

An organization's marketing and communications teams use the networks and accounts that IT and networking manage.



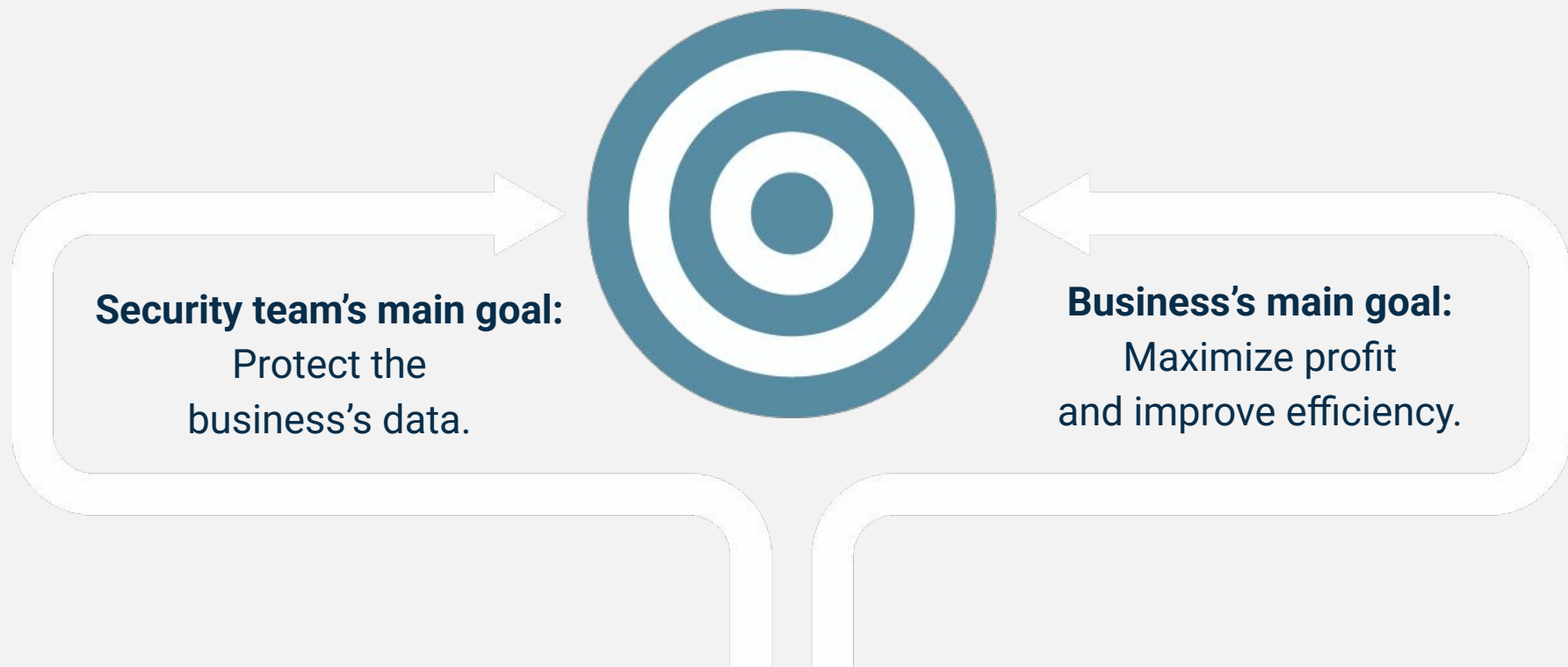


What other examples
can you think of?



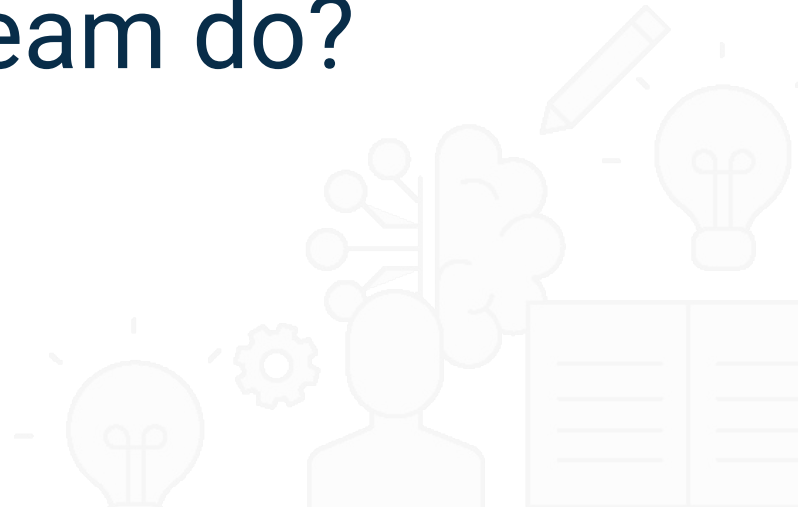
Security Concerns vs. Business Concerns

The most profitable decision isn't always the most secure. Security objectives may be at odds with those of the business.





**What should the
security team do?**



What Should the Security Team Do?

An organization's engineering team proposes an innovative but insecure new feature for its flagship product.

Security Team

Would probably advise against the new feature due to its poor security.



Business-At-Large

Might decide to develop the new feature anyway, believing the potential profit is worth the risk.

What Should the Security Team Do?

The security team must adapt its operations to accommodate a product they know is insecure.

Potential Solutions



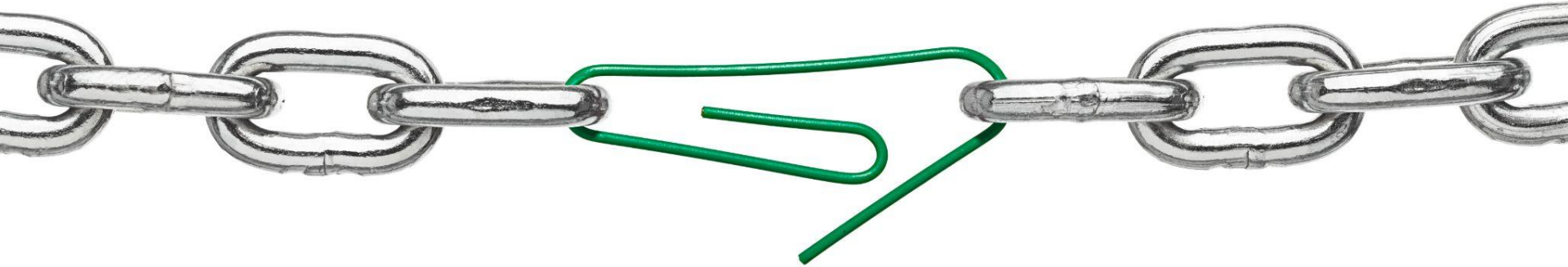
Put in place more aggressive monitoring on data servers likely to be exposed by the new feature.



Advise IT and networking to put in place more sophisticated access controls on important servers and proxies.

100% Security Is Not the Business's Goal

To limit spending and increase profit, businesses often provide only adequate protection for their most important assets.





Security vs. Business

Is the feature worth
the risk?



Security vs. Business: Is the Feature Worth the Risk?

An organization's engineering team proposes an innovative but insecure new feature for its flagship product. The organization performs a **risk assessment** and concludes:

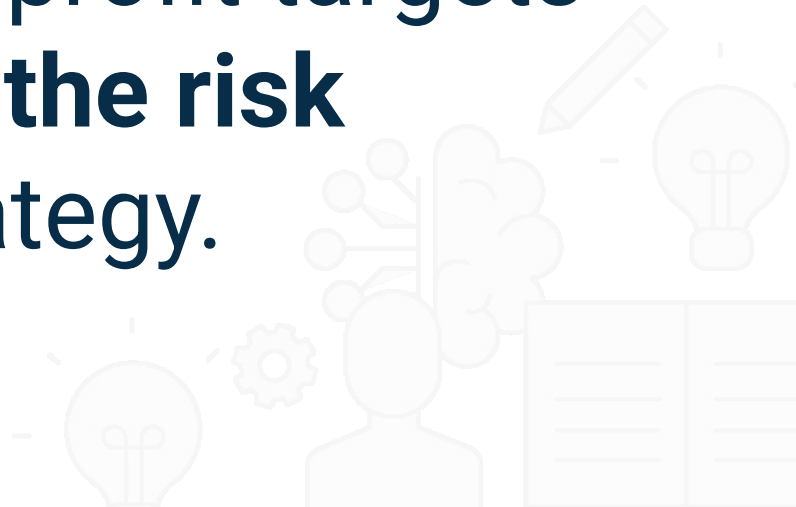


The feature could lead to a 25% increase in quarterly profits.

The feature would also risk exposing an isolated data server containing customer names, usernames, and email addresses, but no other PII (personally identifiable information).



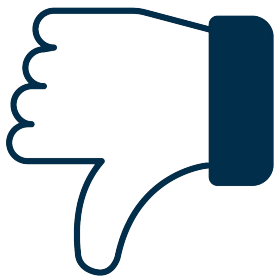
In this case, the **business objective** of achieving profit targets **overrides the risk** of the strategy.



Business Wins

Con

The security team objects to the feature due to its insecurity.



Pro

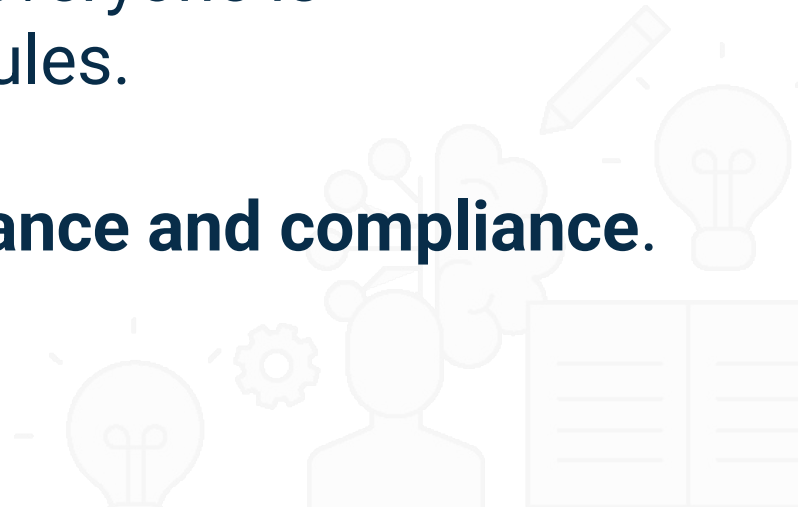
The business decides that the cost of the potential breach of an isolated server with no sensitive PII would be less than the potential profit of the feature.





After making a decision, the business updates its security practices to account for the risk it has undertaken and regularly confirms that everyone is following the rules.

This is **governance and compliance**.





Activity

Considering security and business objectives

In this activity, you'll play the role of a security consultant hired to help a business determine how risky its plans are.

Suggested Time
10 minutes





Time's Up!
Let's review



Questions?

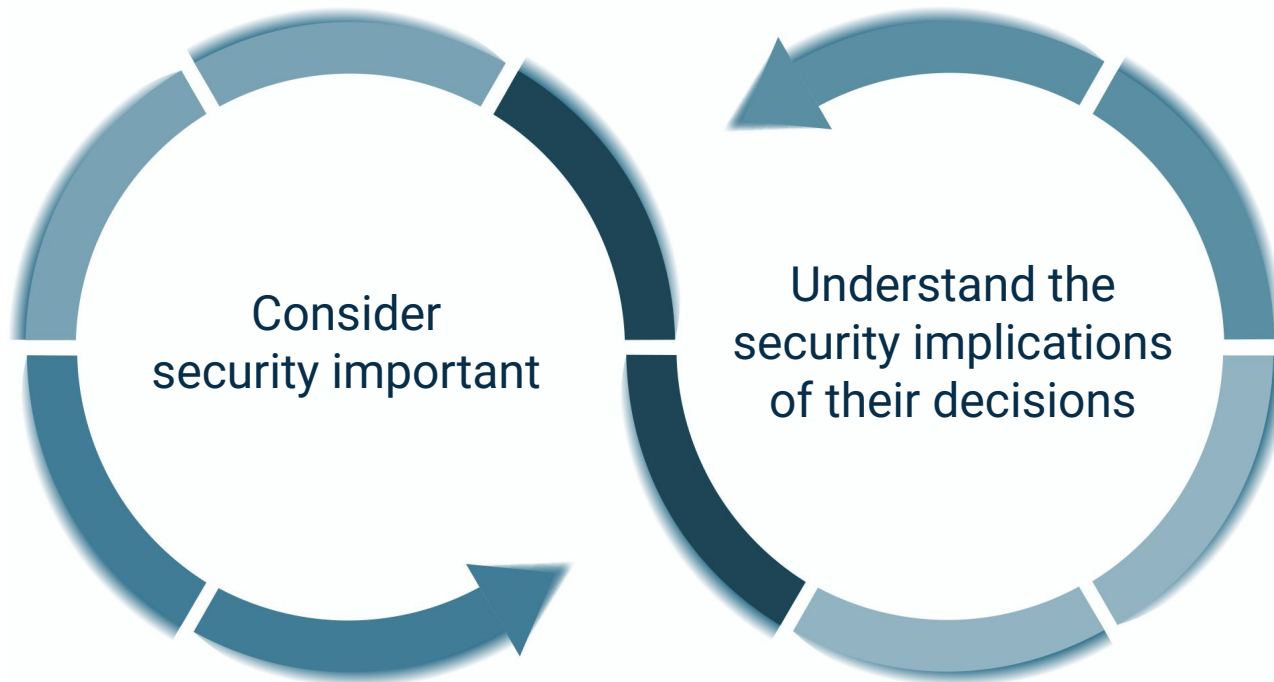




Security Culture **Framework**

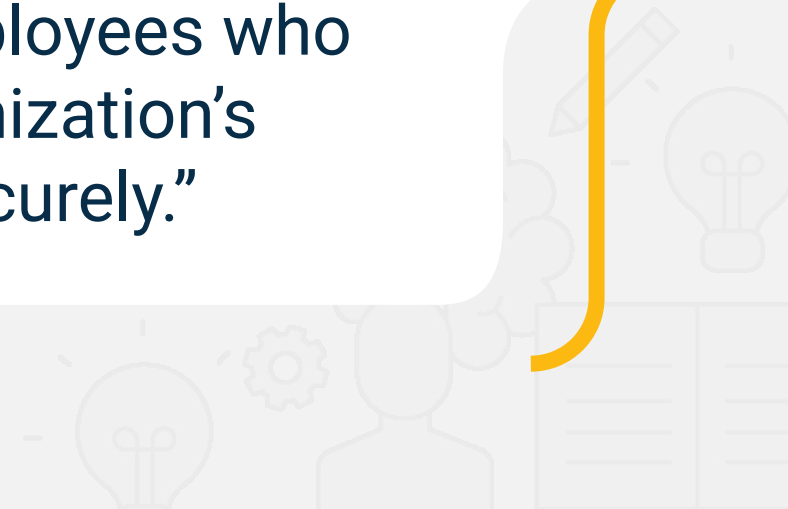
Security Culture

Strong organizational security begins with making sure employees both:





Security culture is the way members of an organization think about and approach security issues. A healthy security culture has employees who are invested in the organization's security and "behave securely."



Security Culture

The health of an organization's security culture is determined by:

01

How important employees consider security.

02

How aware employees are of common security risks.

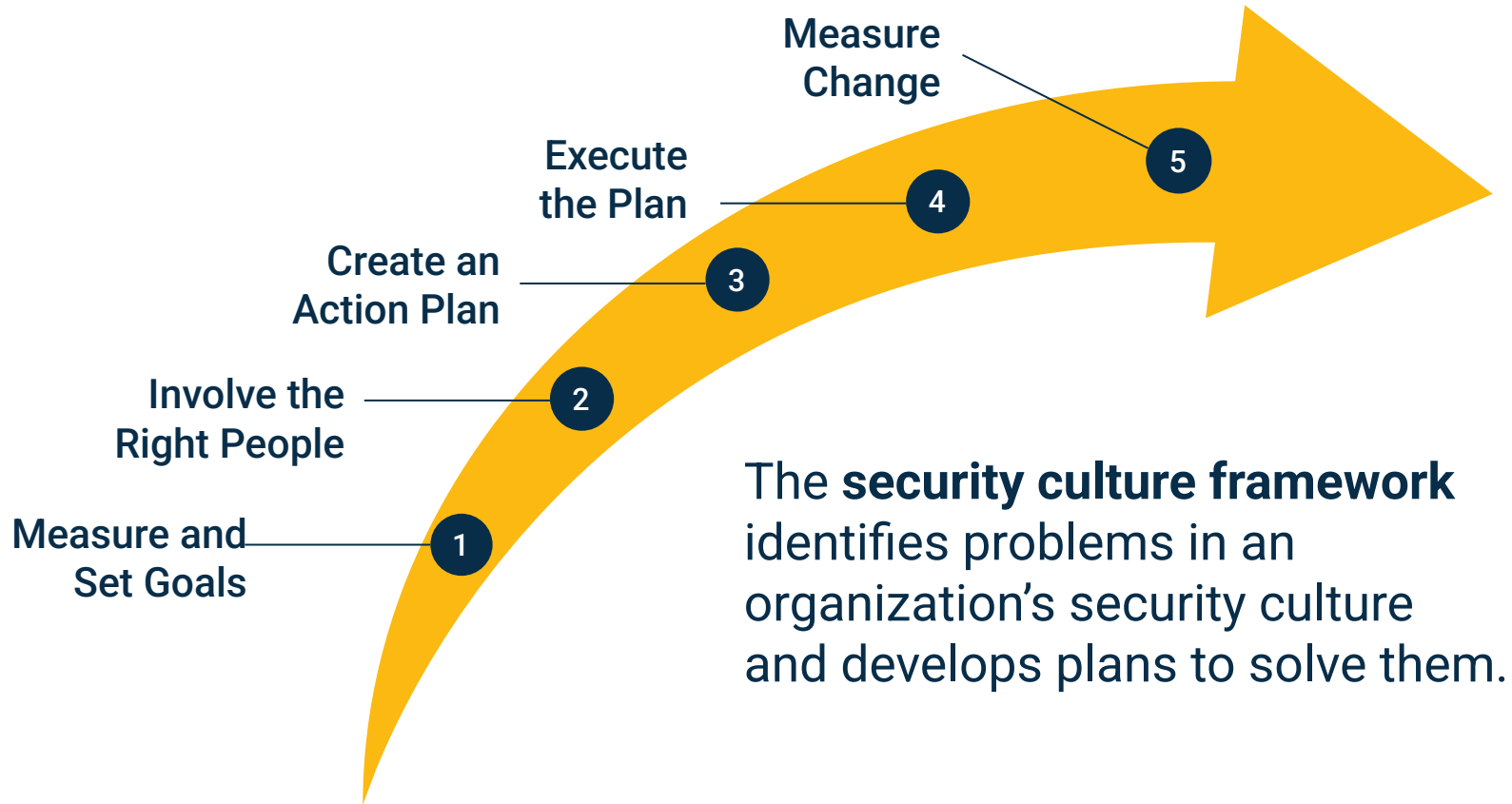
03

Whether employees know how to avoid insecure behavior.



A healthy security culture requires **motivating** employees to value security and **training** them on how to avoid insecure behavior.

Security Culture Framework Steps





Applying the Framework

Security scenario

- Employees are receiving emails to their work accounts from external sources.
- Employees are clicking links and downloading attachments in these emails.
- The organization's security team determined that many of the links and attachments contain malware.



Step 1: Measure and Set Goals

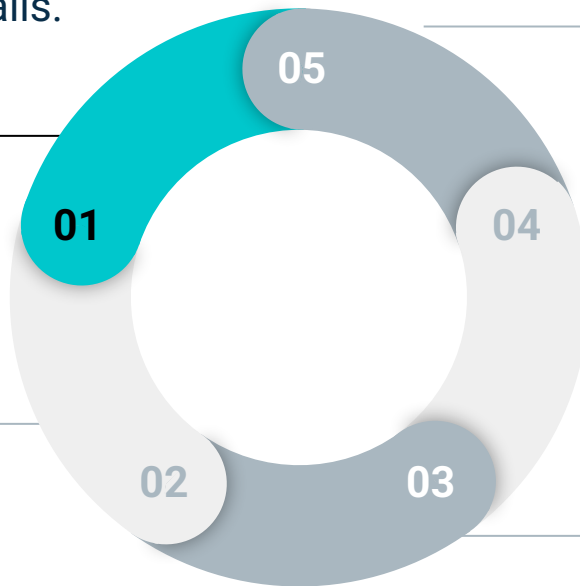
Hire a penetration testing firm to begin a phishing campaign that will send out phishing emails to users in the company. The firm will then keep track of how many users fall for the phishing emails.

Measure and Set Goals

Set a click rate goal of 5%.

Measure this data to determine (1) what percentage of employees fall victim to the phishing and (2) which employees specifically.

Involve the Right People



Measure Change

Execute the Plan

Create an Action Plan



Step 2: Involve the Right People

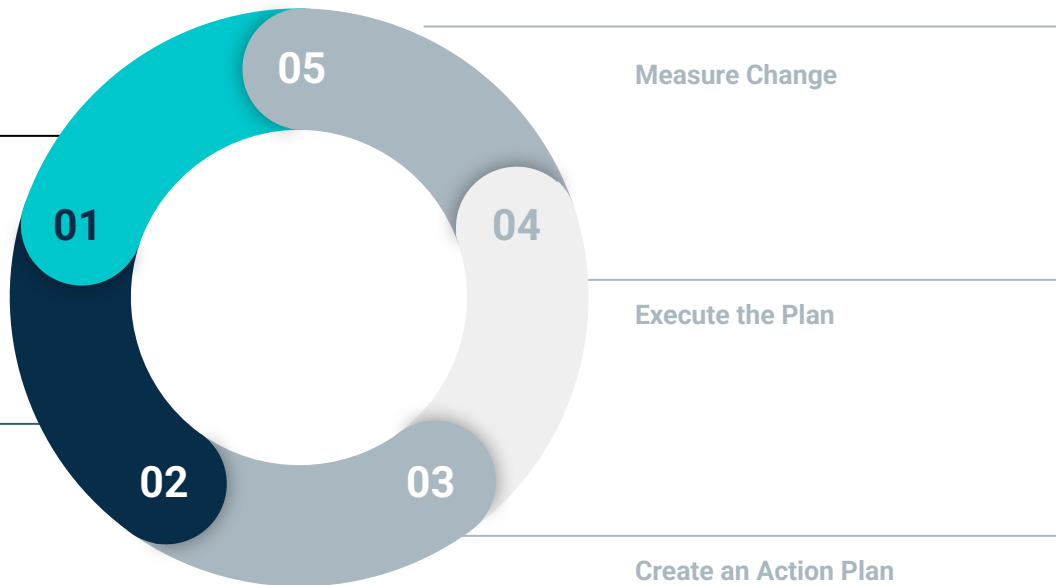
Since this training will affect all members of the organization, inform the executive team about the problem and your decision to implement training.

Measure and Set Goals

Set a click rate goal of 5%.
Measure this data to determine (1) what percentage of employees fall victim to the phishing and (2) which employees specifically.

Involve the Right People

Inform at least the CEO and/or CIO, director of HR, and the person in charge of internal training and communication.





Step 3: Create an Action Plan

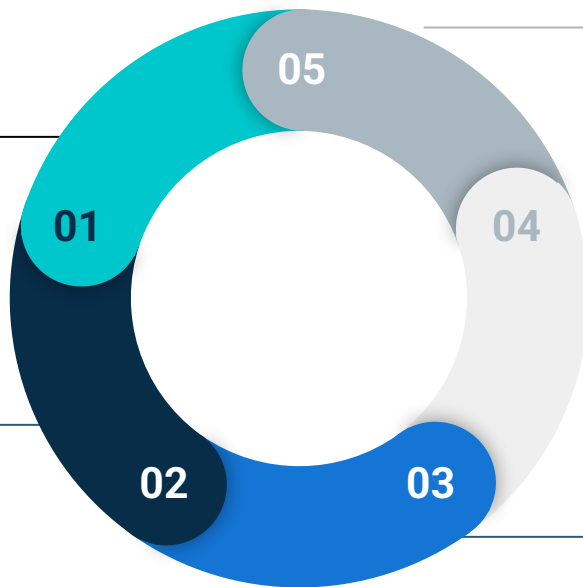
After getting clearance to run the training, plan to deliver an annual cybersecurity awareness training event.

Measure and Set Goals

Set a click rate goal of 5%.
Measure this data to determine (1) what percentage of employees fall victim to the phishing and (2) which employees specifically.

Involve the Right People

Inform at least the CEO and/or CIO, director of HR, and the person in charge of internal training and communication.



Measure Change

Execute the Plan

Create an Action Plan

Develop training to cover the dangers of malware and how malware can spread through phishing and vishing.



Step 4: Execute the Plan

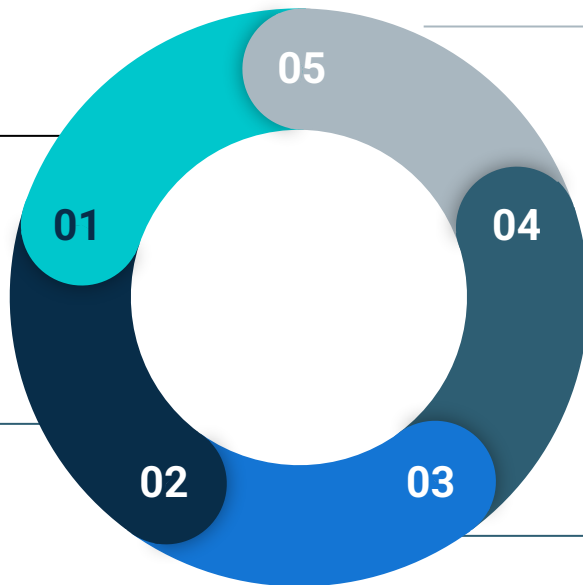
After developing the training, implement it with the goal of training 25% of employees every quarter.

Measure and Set Goals

Set a click rate goal of 5%.
Measure this data to determine (1) what percentage of employees fall victim to the phishing and (2) which employees specifically.

Involve the Right People

Inform at least the CEO and/or CIO, director of HR, and the person in charge of internal training and communication.



Measure Change

Execute the Plan

Implement training with the goal of training 25% of employees each quarter.

Create an Action Plan

Develop training to cover the dangers of malware and how malware can spread through phishing and vishing.



Step 5: Measure Change

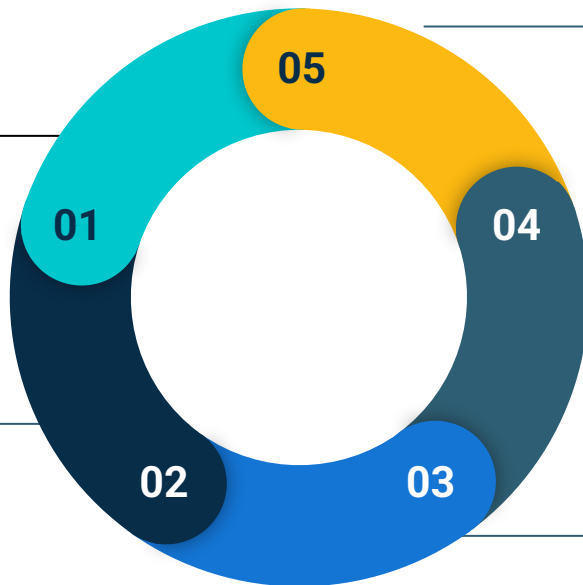
After training the entire company, have the pentesters reimplement the original phishing campaign.

Measure and Set Goals

Set a click rate goal of 5%.
Measure this data to determine (1) what percentage of employees fall victim to the phishing and (2) which employees specifically.

Involve the Right People

Inform at least the CEO and/or CIO, director of HR, and the person in charge of internal training and communication.



Measure Change

Determine success or failure based on goals set in Step 1.

Execute the Plan

Implement training with the goal of training 25% of employees each quarter.

Create an Action Plan

Develop training to cover the dangers of malware and how malware can spread through phishing and vishing.



Activity

Applying the security culture framework Part 1

You'll play the role of a security consultant contracted by a local bank to develop a plan for strengthening physical security.

Suggested Time
15 minutes





Time's Up!
Let's review



Questions?





Break
15 mins



Security Culture Framework: **Action Plan**

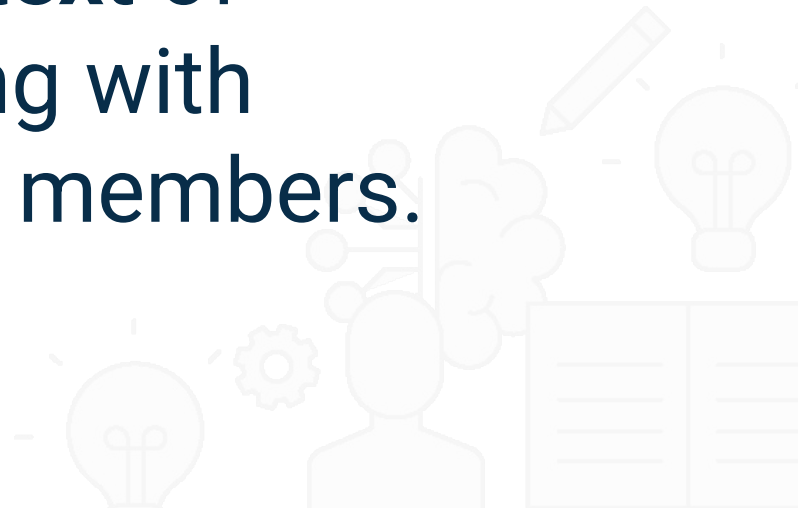


Back to our Security Scenario...

- Employees are receiving emails to their work accounts from external sources.
- Employees are clicking links and downloading attachments in these emails.
- The organization's security team determined that many of the links and attachments contain malware.



Let's go through the steps again, with the **added context** of coordinating with other team members.





Step 1: Security Culture Framework Steps

The security culture framework (SCF) team meets to assess the impact of the phishing incident and the risk posed by future campaigns.

This discussion includes:

01

An assessment of the damage done by the previous phishing incident.

02

Using a pentesting phishing attack to show how many employees download malicious files. This assessment might find a 10% click-through rate, meaning that 10% of employees downloaded malicious email attachments.

03

Setting a target click-through rate. The team might decide that a 5% click-through rate is acceptable.



Step 2: Security Culture Framework Steps

The SCF team manager (in this case, the IR manager) meets with the CISO to explain that the previous phishing attack was successful because 10% of employees downloaded files from unknown email addresses.

They request a budget to carry out a plan that will bring this number down to 5%, and explain how it will profit the business.



Step 3: Security Culture Framework Steps

The SCF team develops a training plan to educate employees.

In addition, the SCF team develops a supplemental security awareness training plan.

This plan will only be delivered to employees who continue to click malicious links after training.



Step 4: Security Culture Framework Steps

After developing the training, the SCF team decides on incentives and disincentives. These will be awarded based on how employees behave during penetration tests and security audits.

Since employees won't know exactly when the assessments are being conducted, the team expects more people to follow the new download guidelines.

Incentives For Not Clicking

A \$40 gift card, free or discounted security conference attendance, and additional vacation time.

Disincentives For Clicking

Supplemental security awareness training and additional random device audits for one quarter.



Step 5: Security Culture Framework Steps

The SCF team collaborates with HR to determine the best dates to run trainings.

During these meetings, the HR team explains that the most reliable way to ensure 100% attendance over the next fiscal year is to have quarterly training sessions, training 25% of employees each time.

SCF and HR coordinate the specific dates and location of the training.



Step 6: Security Culture Framework Steps

The SCF team collaborates with communications to develop and distribute information about the training.



Step 7: Security Culture Framework Steps

The SCF team sets up and implements the training as scheduled.



Step 8: Security Culture Framework Steps

Every quarter, the SCF team contracts the same pentesting firm to run the phishing campaign against all employees who have already been trained.



Step 9: Security Culture Framework Steps

After every test, the SCF team identifies employees who still clicked malicious links, and requires them to go through supplemental security awareness training. In addition, they verify whether the click-through rate drops closer to 5%.



Step 10: Security Culture Framework Steps

After training the entire company, the SCF team runs a final phishing campaign to evaluate the overall effectiveness of the training.

If they find that the click-through rate is 5% or lower, it is considered a success. Otherwise, they might decide to run the training for an additional year, or take a different approach to solving the problem.

What's the (Action) Plan?

Questions you should ask when developing a plan:

01

When will the plan be executed?

The SCF and HR teams will implement the training once every quarter, training 25% of employees each time. This ensures 100% of employees will be trained by the end of the year.

02

When will progress be measured?

The SCF team will implement a phishing campaign each quarter, targeting only the most recently trained cohort. After all cohorts have been trained, a final campaign will test how well everyone follows the new guidelines over time.

03

How will progress be quantified?

The SCF team decides to quantify the click-through rate, which is the percentage of employees who downloaded malicious links from emails. The goal is to decrease this number from 10% to 5%.



Activity

Security culture framework Part 2

In this activity, you will complete the plan you began drafting in Part 1 earlier today.

Suggested Time
20 minutes





Time's Up!
Let's review



Questions?

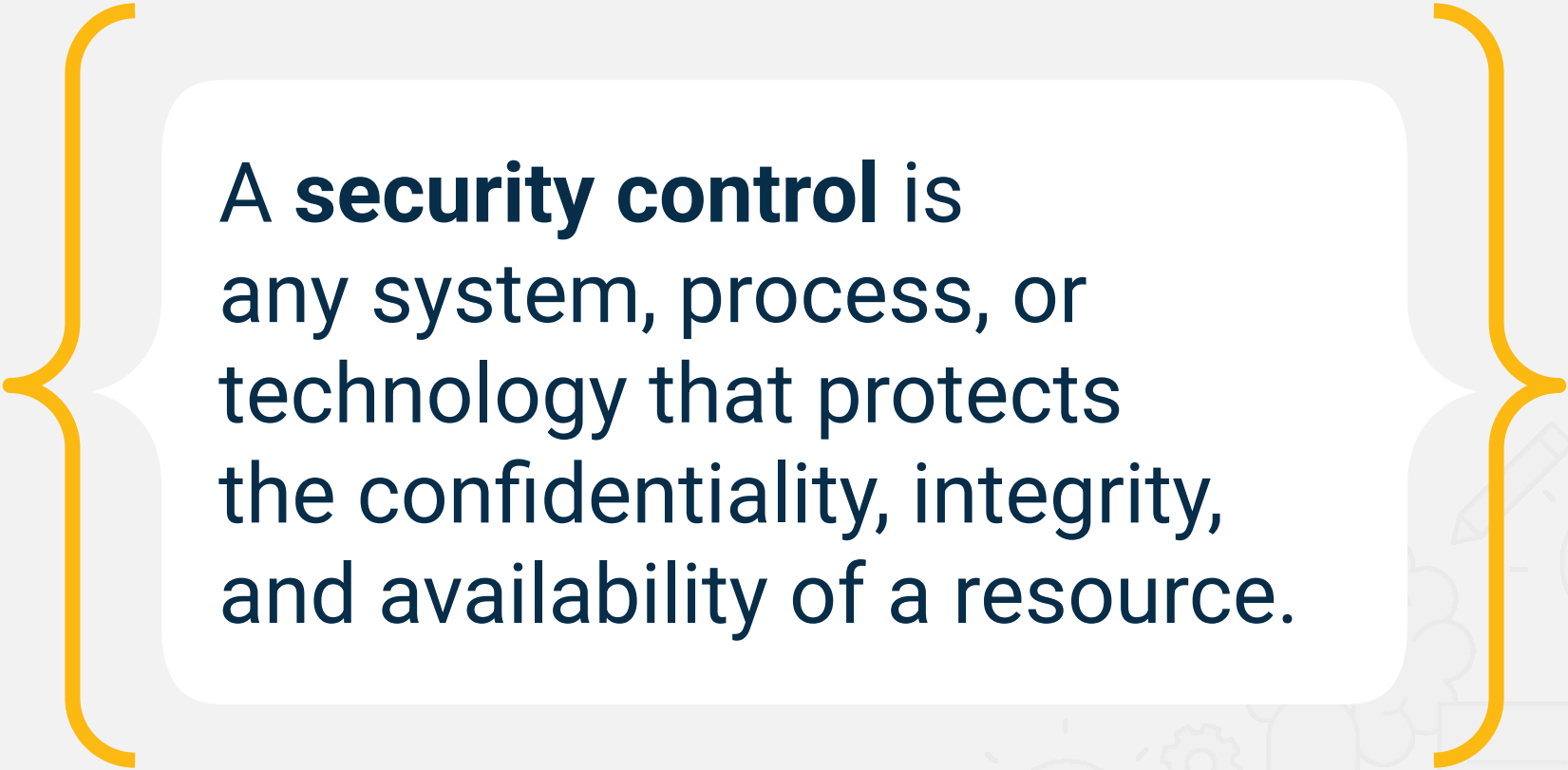




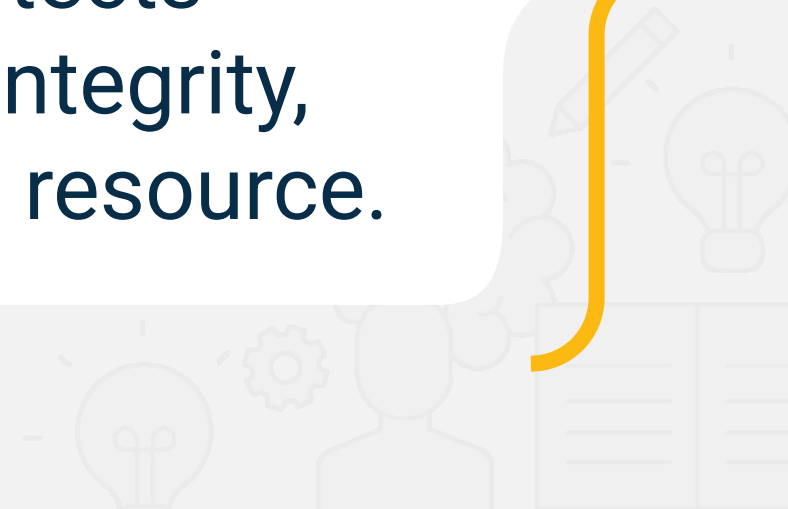
Security Controls



In addition to improving security culture over the long term, the security team should enforce **security controls** that manage issues in the short term.



A **security control** is
any system, process, or
technology that protects
the confidentiality, integrity,
and availability of a resource.



Security Controls and Control Types

Security controls can be administrative, technical, or physical in nature.

Administrative

Example

Requiring employees to follow training guidelines.

Technical

Example

Requiring developers to authenticate using secure shell (SSH) keys rather than passwords.

Physical

Example:

Protecting a building by requiring keycard access.

Security Controls Can Have Different Goals

Preventative Controls	Prevent access with physical or technical barriers. (e.g., keycard access)
Deterrent Controls	Discourage attackers from attempting to access a resource.
Detective Controls	Identify and alert attempts to access a resource.
Corrective Controls	Attempt to fix an incident, and possibly stop it from happening again.
Compensating Controls	Restore the function of compromised systems.

We'll Have More Security Controls in Future Units.

Regardless of their type, all security controls seek to restrain or respond to access of a resource. The following access controls determine who can access specific resources:

Linux

Example

File permissions act as access controls by preventing users from modifying files they don't own.

Networks

Example

Firewalls control access to networks.

Incident Response

Example

Monitoring systems act as detective control.

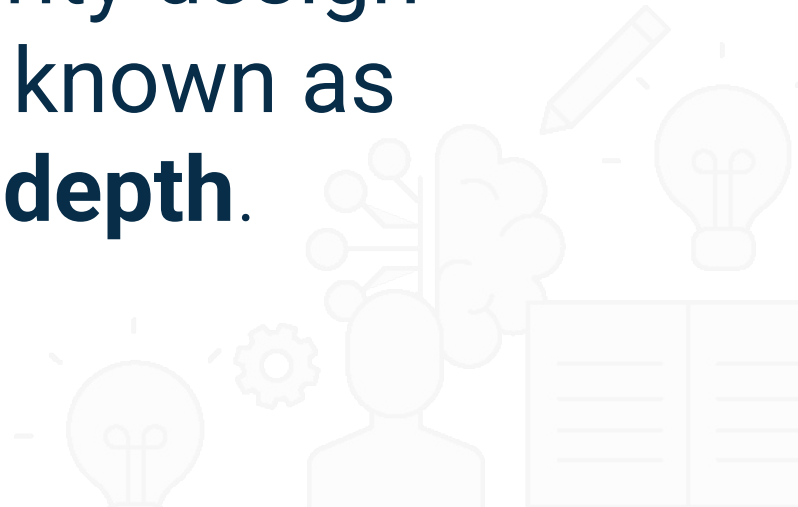


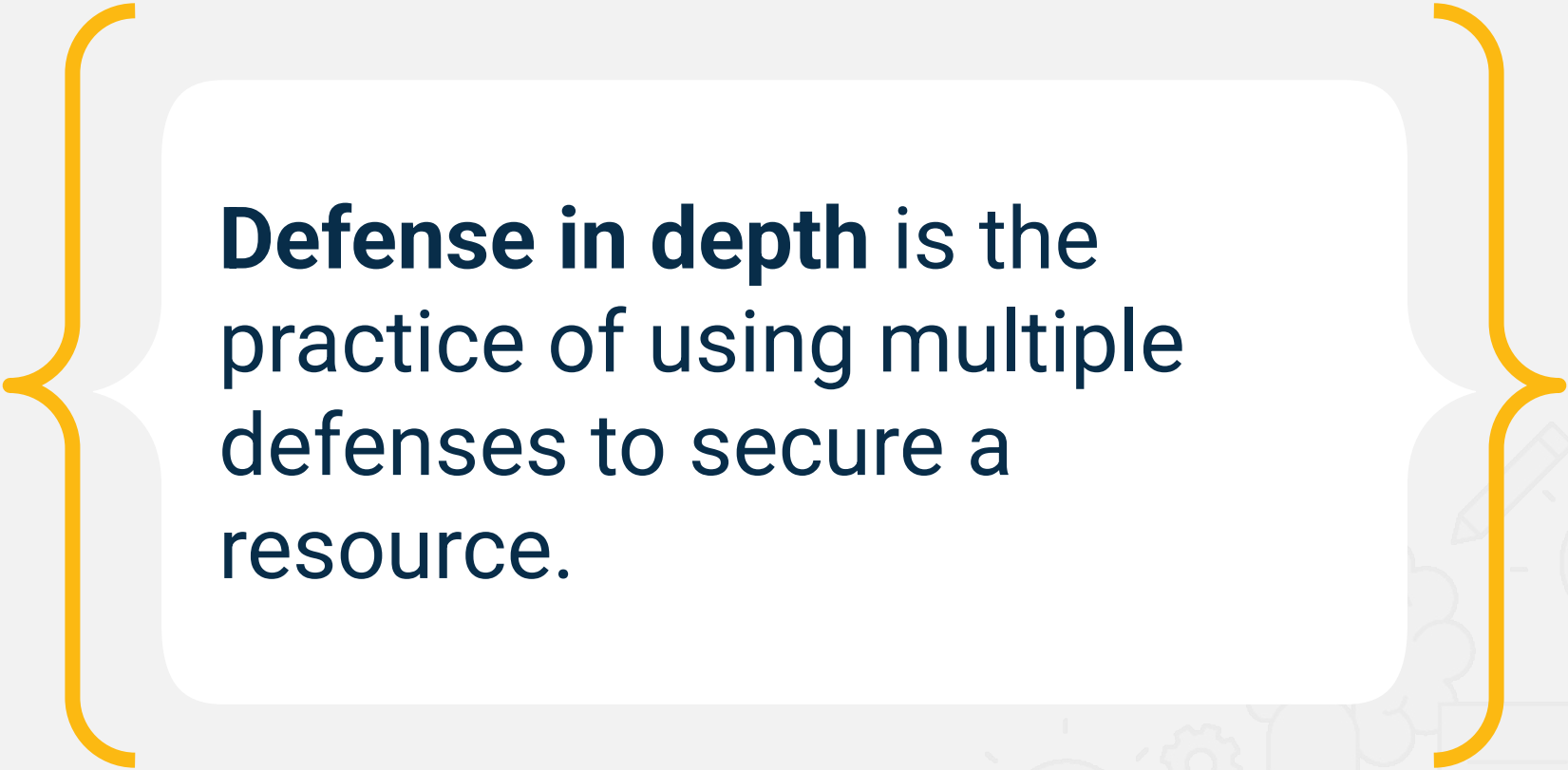
Security controls
check on learning.





Layering security controls
is a fundamental aspect
of the security design
framework known as
defense in depth.





Defense in depth is the practice of using multiple defenses to secure a resource.



Defense in Depth

For example, a secure network may protect an SSH server in three ways:

Technical Control

Hiding the server behind a firewall that only forwards connections from the corporate VPN.

Technical Control

Forcing users to authenticate with SSH keys and passwords.

Procedural Control

Requiring users to generate new keys with new strong passwords every quarter

Control Diversity and Redundancy

A system with multiple layers of protection is said to have **control diversity** because it is protected in multiple ways.

01

Protecting the SSH server with a firewall prevents unwanted connections from unintentional attackers.

02

If an attacker bypasses the VPN, it is still hard to compromise the server. Users must authenticate with SSH keys and passwords so attackers can't easily brute-force the login.

03

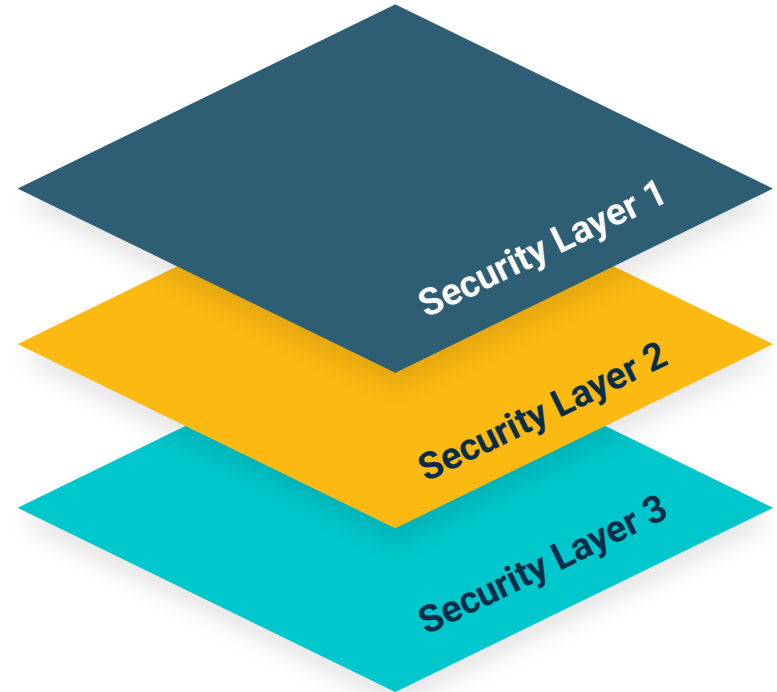
If an attacker does steal both a valid SSH key and its password, they will only be able to compromise the server for a limited time since the stolen key will expire after three months, at most.

Redundancy and Single Points of Failure

Defending the system with multiple methods ensures that it remains protected even if one of them fails.

This concept is known as **redundancy**.

- If the system only has a single control, that control is its **single point of failure**. An attacker can compromise the system by breaking just a single control.
- Creating redundancy eliminates the inherent risk of single points of failure.





Activity

Implementing security controls

In this activity, you will draft the final piece of security recommendations for GeldCorp.

Suggested Time
10 minutes





Time's Up!
Let's review



What We've Covered

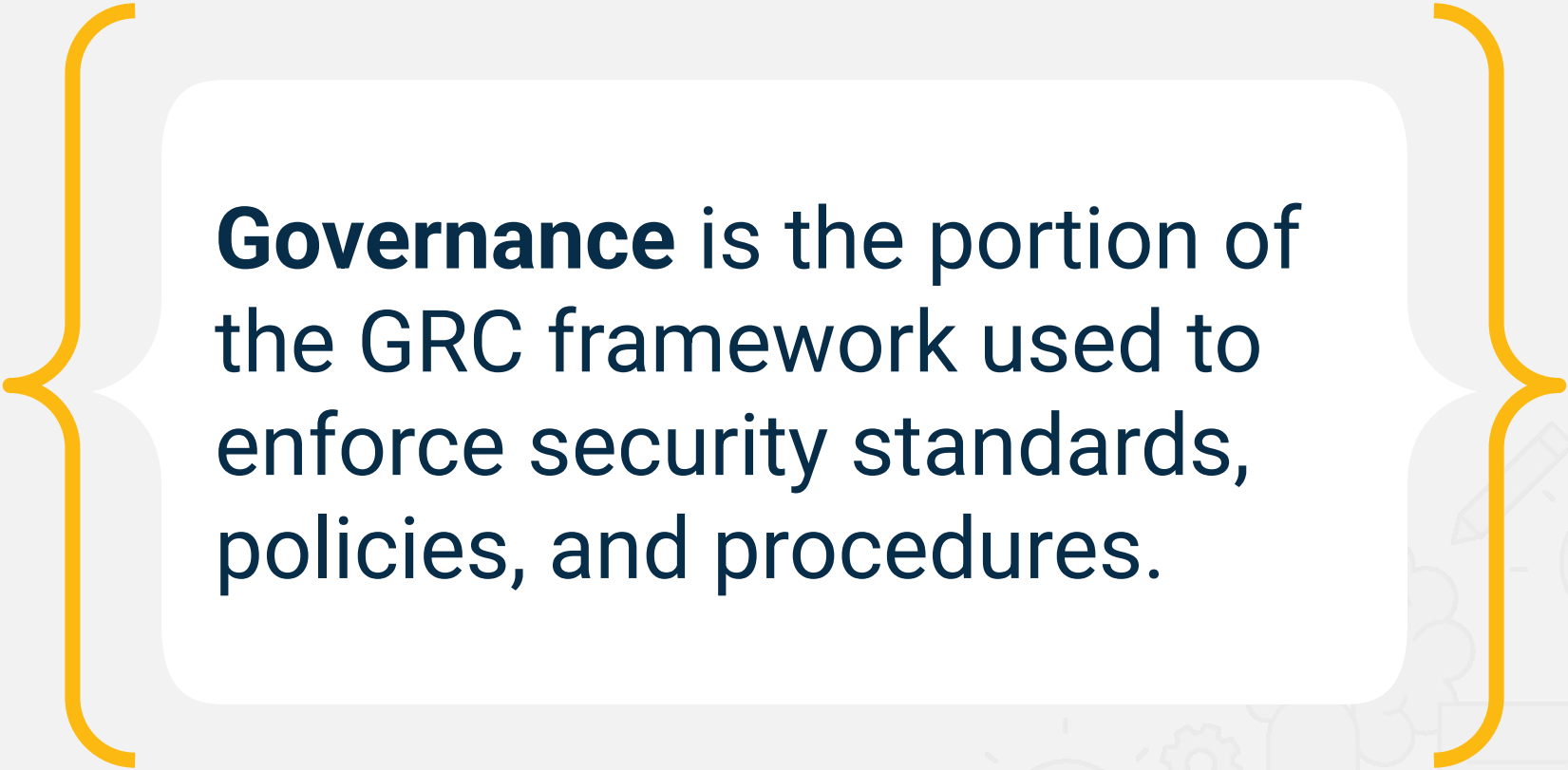
Today's activities put you in the role of a security consultant helping a financial technology firm respond to a major security breach. You had to:

- 1 Identify the source of the breach.
- 2 Develop a plan to improve security and security culture.
- 3 Define metrics to measure if the plan was successful.
- 4 Propose controls, in addition to training, that can mitigate risk.

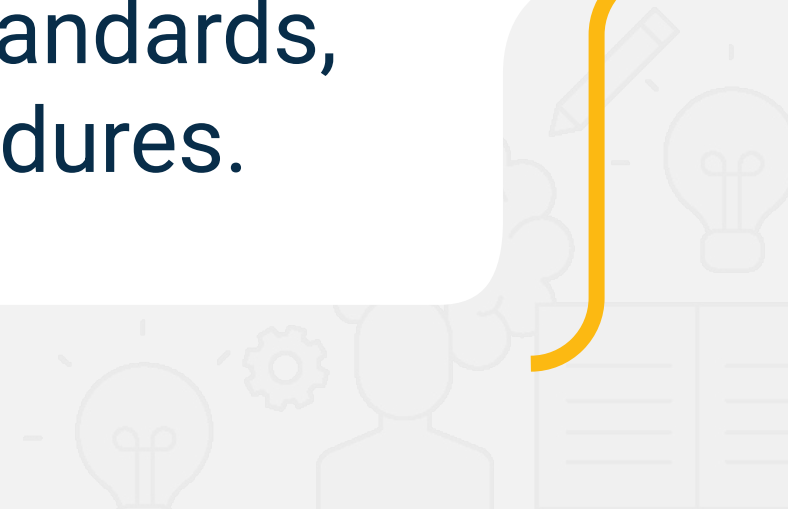


What we learned today
will prepare us to learn
about **governance** later
in the week.



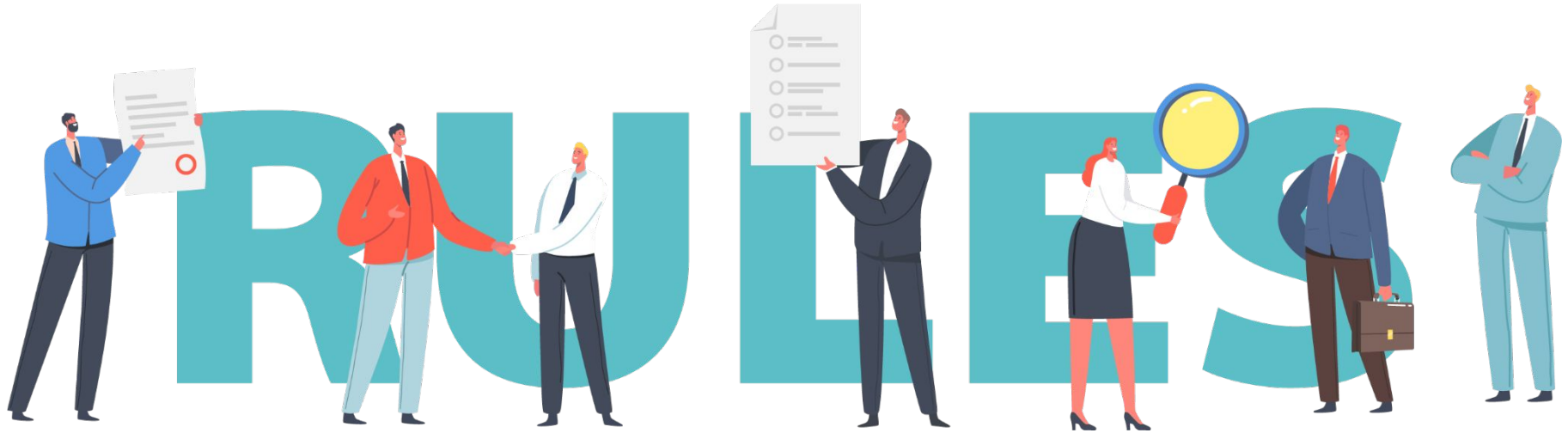


Governance is the portion of the GRC framework used to enforce security standards, policies, and procedures.



Looking Forward...

Now that we have a good understanding of how organizations develop best practices for security, we can learn how they use governance methods to codify and enforce them.





Questions?





Thank You